

AIG-08 · AI IN PROJECT CONTROLS GUIDE

Governing AI on a project — the control framework

Permitted uses, approval authority, records, confidentiality and
model change control, written as project controls

VERSION 1.0 · DRAFT
2026-08-04

PROJECT CONTROLS INSTITUTE GLOBAL, INC.
AI proposes. The professional disposes.

— Summary

A corporate AI policy does not govern a project; project controls do. This document sets out the six control objects that make AI use on a project defensible — permitted-use register, verification tiers, approval authority, verification record, data classification and tool-and-model change control — gives the clauses to write into the project execution plan, and shows how to size and budget the verification effort the framework creates.

— About this document

Document	AIG-08
Series	AI in Project Controls Guide
Version	1.0
Status	draft
Date	2026-08-04
Unresolved placeholders	0

Notice. This document is an educational publication of Project Controls Institute Global, Inc., and does not constitute accounting, tax, legal, financial or other professional advice. It must not be relied upon as such. Where a topic depends on the contract or the governing law, entitlement and treatment vary by jurisdiction; take local advice.

Standards. Standards and frameworks are referred to by name and described in this publication's own words. No standard's text, tables, diagrams or question banks are reproduced. All trademarks remain the property of their respective owners, and no endorsement by any standards body, employer or vendor is implied or should be inferred.

Status. Project Controls Institute Global, Inc. is a Delaware Non-Stock Corporation. The Institute has been developed with reference to ISO/IEC 17024 personnel-certification principles and is **not accredited** by ANAB, IAS or any other accreditation body. It intends to seek 501(c)(3) recognition, which has not been granted. No governmental approval, academic equivalence, or guaranteed employment, promotion or salary outcome is claimed or implied.

Examples. All worked examples are illustrative and fictional. Figures are chosen to demonstrate a method, not to describe any real project, organisation or market. Sample examination items, where they appear, are study material maintained separately from any live examination bank.

Completeness. Passages marked **[CONFIRM: ...]** are operational or market facts that have not yet been confirmed from a cited source. A document carrying them is a working draft and is not approved for publication.

© 2026 Project Controls Institute Global, Inc. · All rights reserved.

Contents

1. The gap a corporate policy leaves.....	4
2. Six control objects.....	4
3. The permitted-use register	5
4. Verification tiers.....	6
5. Confidentiality of commercially sensitive data	7
6. Tool and model change control.....	7
7. What goes in the project execution plan	8
8. Knowing whether the framework is working	9
9. How this goes wrong	9
10. Worked example — pricing the verification the framework creates.....	9
11. Checklist.....	10
Related	11
Sources and standards.....	11
Status and version	11

Governing AI on a project — the control framework

In one paragraph. A corporate AI policy does not govern a project; project controls do. This document sets out the six control objects that make AI use on a project defensible — permitted-use register, verification tiers, approval authority, verification record, data classification and tool-and-model change control — gives the clauses to write into the project execution plan, and shows how to size and budget the verification effort the framework creates.

Who this is for. Project controls managers, project directors, PMO leads and heads of function who answer for AI-assisted numbers, and the assurance and audit staff who test the answer.

— 1. The gap a corporate policy leaves

Most organisations that have adopted AI have written a policy: confidential data must not go into public tools, outputs must be verified, staff remain accountable. All correct, and none of it governs a project.

A project needs to know: on this project, which task may use AI, on which data, in which tool, verified to what standard, approved by whom, recorded how, retained how long. A corporate policy answers none of those questions. It states a principle; a project needs a control.

It is the distinction controls professionals already make about cost. "We will manage cost carefully" is a policy; a cost breakdown structure, a change control procedure, delegated authority thresholds and a monthly reconciliation are controls. AI governance fails for the reason cost control fails: the principle was written and the control was not.

This document is the control set — the Institute's position, **AI proposes; the professional disposes**, turned into artefacts with owners, frequencies and fields.

— 2. Six control objects

Everything that follows attaches to one of six objects. A framework with all six is auditable; one with fewer should name which is missing, and why.

#	Control object	What it fixes	Owner (typical)	Cadence
1	Permitted-use register	Which task, capability class, data class and tool	Project controls manager	Reviewed at each stage gate; entries added on request
2	Verification standard (tiers)	How hard an output is checked before use	Project controls manager	Set at mobilisation; changed by documented decision only
3	Approval authority	Who may decide what, at what threshold	Project director	Set at mobilisation; aligned to delegated authority
4	Verification record	Evidence that the check happened	Output owner (named)	Per material output
5	Data classification	What may go into which tool	Information manager	Inherited; mapped to project artefacts at mobilisation
6	Tool and model change control	What happens when the tool changes under you	Named tool owner	Re-validation on trigger and on a stated calendar

Objects 3 and 4 are owned elsewhere in this series: the decision boundary and authority thresholds in [AIG-10 – Human in the loop: what AI may and may not decide](#), the audit-trail content in [AIG-09 – Bias, explainability and auditability](#). This document owns objects 1, 2, 5 and 6, and the assembly of all six into the project execution plan.

— 3. The permitted-use register

The register is the operative document — not a list of approved products but of **approved uses**, because the same tool is appropriate for one task and reckless for another. One row per use:

Column	Content	Why it is there
Use reference	AI-U-nn	So a record or an audit finding can cite it
Task	The controls task in the function's own words, e.g. "draft first-cut control account variance narrative"	A task, not a capability: "summarisation" is not a use
Capability class	Assistant, retrieval-grounded, tabular analysis, forecasting model, process automation, transcription	Ties the row to its class-specific failure mode (AIG-02)
Approved tool	The named instance, and whether it is the governed enterprise deployment	The same product ungoverned is a different control
Maximum data classification	The highest classification permitted in this use	The most commonly breached rule
Grounding required	Yes/no, and against what corpus	Grounded and ungrounded answers differ in risk
Verification tier	1, 2 or 3 (§4)	Fixed in advance, not chosen under deadline
Output owner role	The role accountable for this use's outputs	Accountability precedes the output
Approved on / review due	Dates	Enforces §6 re-validation
Status	Approved · Provisional (pilot) · Suspended	A suspended row beats a deleted one

Three rules give the register its force. **Absence is prohibition** — a use not in the register is not permitted, the only formulation that survives contact with a busy team, because "use your judgement" produces an unbounded surface with no audit trail. **Provisional means measured** — a pilot enters as Provisional with a success measure and an end date, and a pilot that misses its measure is closed, not extended (AIG-11 §8). **Requests are cheap and logged** — a framework people cannot add to is one they work around, so provide a request route to the register owner and log refusals with reasons. The refusal log is the most informative document in the framework after six months.

— 4. Verification tiers

The commonest governance failure is a uniform rule — "all AI outputs must be verified" — which is either unaffordable or ignored. Set three tiers; assign one to every register row.

Tier 1 — Independent recomputation. The reviewer reproduces the number by an independent route without reference to the model's working, then compares; assumptions, method and the reason for the method are recorded. Applied to anything reported outside the project, anything entering a baseline or a decision-funding forecast, and anything with contractual effect.

Tier 2 — Source verification. Every figure and extracted item traced to its source record, every causal claim checked against the underlying analysis, and anything the model could not ground deleted rather than softened. Applied to internal analysis, extraction, narrative drafting over verified data and register enrichment.

Tier 3 — Sampled acceptance with monitoring. High-volume, low-unit-consequence output — coded transaction lines, metadata enrichment — accepted on a defined sample with an error threshold and monitored for drift. Sample size, threshold and the action on breach are written down before the first run.

Three points decide whether tiers work.

- **The tier belongs to the use, not the day.** It is set in the register when the use is approved. Nobody chooses their own tier at 17:00 on a reporting day.
- **A tier is lowered only by documented decision** from the register owner, on measured error rate — not on time elapsed without incident. It is a control change, logged as one.
- **Tier 3 is not "no verification".** It swaps per-item review for a sample plus a monitoring obligation, and the monitoring is what gets dropped. Name the person who reads the drift number, and the month.

— 5. Confidentiality of commercially sensitive data

Four things make project confidentiality more than a compliance formality: unit rates and build-ups, subcontract terms and commercial positions, claims and dispute strategy, and personal data in correspondence and resource records. In joint ventures, some is confidential between the parties on your own project.

Map the classification before mobilisation, not at first use. Write down which project artefacts fall into which class of the organisation's scheme: cost model, risk register, subcontract set, correspondence file, resource plan, claims file. The register's "maximum data classification" column is meaningless until this map exists.

The pre-entry test. Before material enters any tool, the person entering it answers three questions: what is this material's classification; is this tool approved for that classification; would the data owner be content to watch me do this. The third catches what the first two miss — notably joint-venture and client data whose classification nobody has set.

Preparation is a control. Removing names, rates or party identifiers before analysis often converts a prohibited use into a permitted one at negligible cost; record what was removed, because the analysis's limitations follow from it. A retrieval system indexed across the project must inherit the underlying access model, tested with a named unprivileged account before go-live. Where data is processed, under whose law, and whether it improves the vendor's models are settled at purchase (AIG-11 §3): the register records those answers, it does not discover them.

— 6. Tool and model change control

This is the control object most frameworks omit, and the one that ages an otherwise sound framework into a false assurance.

The system you validated is not the system you are using. Hosted models are updated by their vendors, platform features change on the vendor's release cycle, a retrieval corpus changes every time someone files a document, and a forecasting model's world changes as the portfolio changes. Nothing in your project changed, and the behaviour did. Four controls follow.

Version identification. The verification record captures the tool, and the model or version identifier where the vendor exposes one. Where it exposes nothing — common for embedded platform

features — record that: "version unknown" is a finding, and caps how far a number can later be re-constructed.

Re-validation triggers. Re-validate on any of: a vendor-notified model or feature change; a change to the retrieval corpus's scope or permissions; a change to an upstream data structure such as the cost breakdown structure or code of accounts; a project stage gate; a failed sample under Tier 3; and a stated calendar cadence for anything at Tier 1. Write the trigger list into the plan.

Re-validation method. Re-run a versioned set of test cases whose correct answers were established by professionals and compare with the previous run — the same instrument used to evaluate the tool at purchase, kept and re-used. [AIG-09](#) §7 covers what a change in the results means.

Change is announced, not discovered. The register's tool owner tracks vendor release notes and tells users when behaviour has changed. A user who discovers a change by getting a different answer has already relied on the old one.

— 7. What goes in the project execution plan

The framework lives in the project execution plan, or the controls plan where the function keeps one. Ten clauses, numbered so an assurance finding can cite them — see [TPL-01 – Project controls execution plan](#).

AI-1 Scope. Which parties the section binds — staff, contractors, secondees, consultants and, where the contract allows, subcontractors producing controls deliverables — and that accountability for every output rests with a named individual, not a tool.

AI-2 Permitted-use register. Where it lives, who owns it, how a use is added, and that a use not in the register is not permitted.

AI-3 Data classification and prohibited data. The classification map (§5), the maximum classification per approved tool, and material that may not enter any tool on this project.

AI-4 Verification tiers. The three tiers, what each requires, and that a tier is assigned in the register and lowered only by documented decision on measured evidence.

AI-5 Approval authority and sign-off. The decision boundary and thresholds, cross-referenced to the project's delegated authority schedule so the two cannot diverge. See [AIG-10](#).

AI-6 Disclosure. Where AI assistance is disclosed — client, board, auditor, certifier — and in what form. Contract and reporting requirements govern; where they are silent, the project states its own rule rather than leaving it to individuals.

AI-7 Records and retention. What a verification record contains, where it is filed, and for how long. Retention matches the project's records schedule: a number that outlives its evidence is undefendable.

AI-8 Tool and model change control. The four controls of §6, with the named tool owner and the trigger list.

AI-9 Incidents and near-misses. What is reported, to whom, within what period; that a near-miss is reported as readily as an incident; and that the register and plan are updated where one shows a gap.

AI-10 Review cadence and ownership. Who owns this section, when it is reviewed, and that everyone using AI on the project is briefed before first use.

— 8. Knowing whether the framework is working

Three tests, none of which is "we have a policy". **Reconstruction:** pick an AI-assisted number that left the project last quarter and ask its named owner to reconstruct it — source data, method, what the model produced, what changed in review, who signed, when; more than an hour means the record is not working. **Refusals:** no refusals logged in six months means the framework is unused or unconsulted, both findings. **Incidents:** zero incidents and zero near-misses across an active function means near-misses are not reported, and the first thing you learn about will be an incident that reached the client.

— 9. How this goes wrong

Policy without register. An AI policy exists and no project-level permitted-use register. Everyone is "being careful", nobody can say which tasks use AI on what data, and nothing is auditable or prohibited.

The register nobody can add to. Additions require a monthly committee. Within one reporting cycle staff have gone around it, and the shadow use is unmonitored and invisible — worse than the use the framework meant to prevent.

Uniform verification, quietly abandoned. "Everything is verified" survives four weeks. Because no tier distinguishes a board forecast from a metadata field, the rule is impossible, so it is ignored — and it is ignored for the board forecast too.

Verification recorded as a tick. "Verified — yes" proves nothing; under challenge the reviewer cannot say what they recomputed or against what. [AIG-09](#) §3 gives the fields that make a record load-bearing.

Governance costed at zero. The business case counted licences and time saved, not verification hours, so the framework arrives with no budget and is treated as optional. §10 prices this deliberately.

The silent upgrade. A tool's model is updated, outputs shift, and nobody re-validated because nothing in the project changed. Three months of numbers rest on an assurance that expired without notice.

Confidentiality by exhortation. The rule is "no confidential data in public tools", but the project never classified its artefacts, so staff judge sincerely about material they have no classification for — and the joint-venture partner's rates end up in a public assistant.

The framework as a shield. Documents exist, boxes are ticked, and nobody has refused an output, re-validated a tool or investigated a near-miss. Worse than nothing: it manufactures confidence.

— 10. Worked example — pricing the verification the framework creates

Illustrative figures. One project, one month, then annualised. Currency stated as USD; loaded labour rate assumed; rounding to the nearest whole unit.

Setup. The register lists nine uses producing material outputs monthly: **four at Tier 1** (cost forecast, contingency drawdown analysis, schedule-risk input pack, client cost report) and **five at Tier 2** (variance narratives, register enrichment, contract-term extraction, exception commentary, risk-register update). Tier 1 verification averages **90 minutes** per output, Tier 2 **30 minutes**. Loaded cost of the reviewing grade: **USD 85 per hour**.

Formulae. $\text{monthly minutes} = (\text{Tier 1 count} \times \text{Tier 1 minutes}) + (\text{Tier 2 count} \times \text{Tier 2 minutes})$;
 $\text{annual hours} = (\text{monthly minutes} \div 60) \times 12$; $\text{annual cost} = \text{annual hours} \times \text{loaded rate}$.

Substitution. Tier 1 = $4 \times 90 = 360$ minutes; Tier 2 = $5 \times 30 = 150$ minutes; monthly = $360 + 150 = 510$ minutes = $510 \div 60 = 8.5$ hours; annual = $8.5 \times 12 = 102$ hours; annual cost = $102 \times 85 = \text{USD } 8,670$.

Result. The framework costs **102 reviewer-hours and USD 8,670 a year** on this project, before any tool licence.

Interpretation. The number does three jobs. It goes in the controls budget as a line, so verification is resourced rather than expected. It goes in the value case as a cost netted against whatever the AI use saves — a case that omits it is not a case. And it is the honest test of scope: at thirty material outputs a month, verification is $(4 \times 90) + (26 \times 30) = 360 + 780 = 1,140$ minutes, or **19 hours a month**, at which point the function resources it, moves lower-consequence uses to Tier 3 with monitoring, or removes uses from the register. What it must not do is keep the register and abandon the tier — §9's third failure.

— 11. Checklist

- [] A permitted-use register exists for this project, with an owner and a review date.
- [] Every row states task, capability class, tool instance, maximum data class, grounding, tier and output-owner role.
- [] "A use not in the register is not permitted" is written in the plan; a request route exists; refusals are logged.
- [] Three tiers are defined, every row carries one, and lowering a tier needs a documented decision on measured evidence.
- [] The data classification map names actual project artefacts, and each tool has a maximum classification plus recorded residency and training-on-your-data answers.
- [] Retrieval permissions have been tested with a named unprivileged account.
- [] Each tool has a named owner, a re-validation trigger list and a versioned test set.
- [] Verification records are filed where an auditor can find them, retained to the project's records schedule.
- [] Clauses AI-1 to AI-10 are in the plan, and verification effort is a costed line in the controls budget.
- [] An incident and near-miss route exists, and someone has read the log this quarter.

When an AI-assisted number is challenged — by a client, an auditor, an adjudicator or a board — the answer should be a record and a name produced within the hour, not a search for who ran what, in which tool, on which day.

— Related

- [AIG-09 – Bias, explainability and auditability](#) — what a verification record must contain to make a number reconstructable
- [AIG-10 – Human in the loop: what AI may and may not decide](#) — the boundary and thresholds control object 3 depends on
- [AIG-11 – Evaluating AI tools – a buyer's due-diligence guide](#) — how residency, training and versioning answers are obtained
- [ETH-05 – The ethical use of AI and data](#) — the conduct obligations underneath the controls
- [TPL-01 – Project controls execution plan](#) — the plan these clauses go into

— Sources and standards

- PCI Body of Knowledge, Domain 13 (AI for Project Controls & Project Management), [docs/bok/](#) — the governance and assurance material this document draws on, explained in our own words.
- The Institute's candidate AI-use policy ([docs/downloads/](#)).

Standards named but not reproduced: ISO/IEC 42001 (management systems for artificial intelligence) and ISO 31000 (risk management), the natural reading for a function formalising this at organisational rather than project level. This is a project controls framework, not a management-system standard, and not a route to conformity with either.

— Status and version

Founding-stage document · Version 1.0 · draft · Reviewed under PCI governance. PCI makes no claims of accreditation or recognition beyond what is true today.